

1.

MALWARE OUTBREAK INCIDENT RESPONSE PLAYBOOK

NIST SP 800-61 Rev. 2 Aligned

Microsoft Azure & Defender Environment

DOCUMENT CONTROL

CyberInfiniti Ltd | Page 2

Version History

Version	Date	Author	Description
1.0	03/07/2025	SOC Analyst Team	Initial draft – Playbook development
1.1	03/07/2025	SOC Lead	Peer review and process validation
1.2	03/07/2025	CISO Office	Approved for distribution

Distribution List

- Chief Information Security Officer (CISO)
- IT Infrastructure Manager
- SOC Lead & SOC Analysts
- Incident Response Team
- Legal & Compliance
- Client Account Managers (as applicable)

Review Cycle

This playbook shall be reviewed quarterly, after any major malware incident, or when significant changes to the Azure/Microsoft environment occur.

Scope & Applicability

This playbook applies to all malware-related incidents detected across client environments managed by CyberInfiniti Ltd, specifically within Microsoft 365, Azure, and Windows-based infrastructures. It covers the full NIST SP 800-61 incident response lifecycle and is designed to be executed by the CyberInfiniti SOC team using Microsoft Defender for Endpoint, Microsoft Sentinel, and supporting Azure-native security tooling.

Referenced Standards & Frameworks

- NIST SP 800-61 Rev. 2 – Computer Security Incident Handling Guide
- MITRE ATT&CK Framework – Enterprise Tactics & Techniques
- Microsoft Security Best Practices & Azure Security Benchmark
- CyberInfiniti Ltd Internal Incident Response Policy v3.

TABLE OF CONTENTS

CyberInfiniti Ltd | Page 3

1.	Playbook Overview & NIST Process Flow	4
2.	Phase 1: Prepare	5
3.	Phase 2: Detect	6
4.	Phase 3: Analyse	7
5.	Phase 4: Contain	8
6.	Phase 5: Eradicate	9
7.	Phase 6: Recover	10
8.	Phase 7: Post-Incident Handling	11
9.	Indicators of Compromise (IoCs) Reference	12
10.	Communication & Escalation Plan	13
11.	Affected Systems & Appendix	14

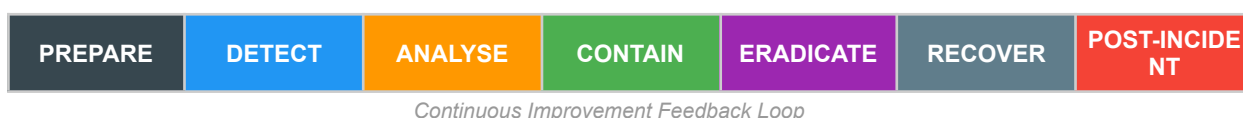
Purpose

This playbook provides the CyberInfiniti Ltd SOC team with a standardised, repeatable process for responding to malware outbreak incidents across managed client environments. It aligns with NIST SP 800-61 Rev. 2 and is tailored for Microsoft Azure and Defender-based security stacks.

Incident Type: Malware Outbreak

Covers: RATs, Infostealers, Trojans, Worms, Ransomware, Cryptominers, Loaders/Droppers

NIST SP 800-61 Incident Response Lifecycle



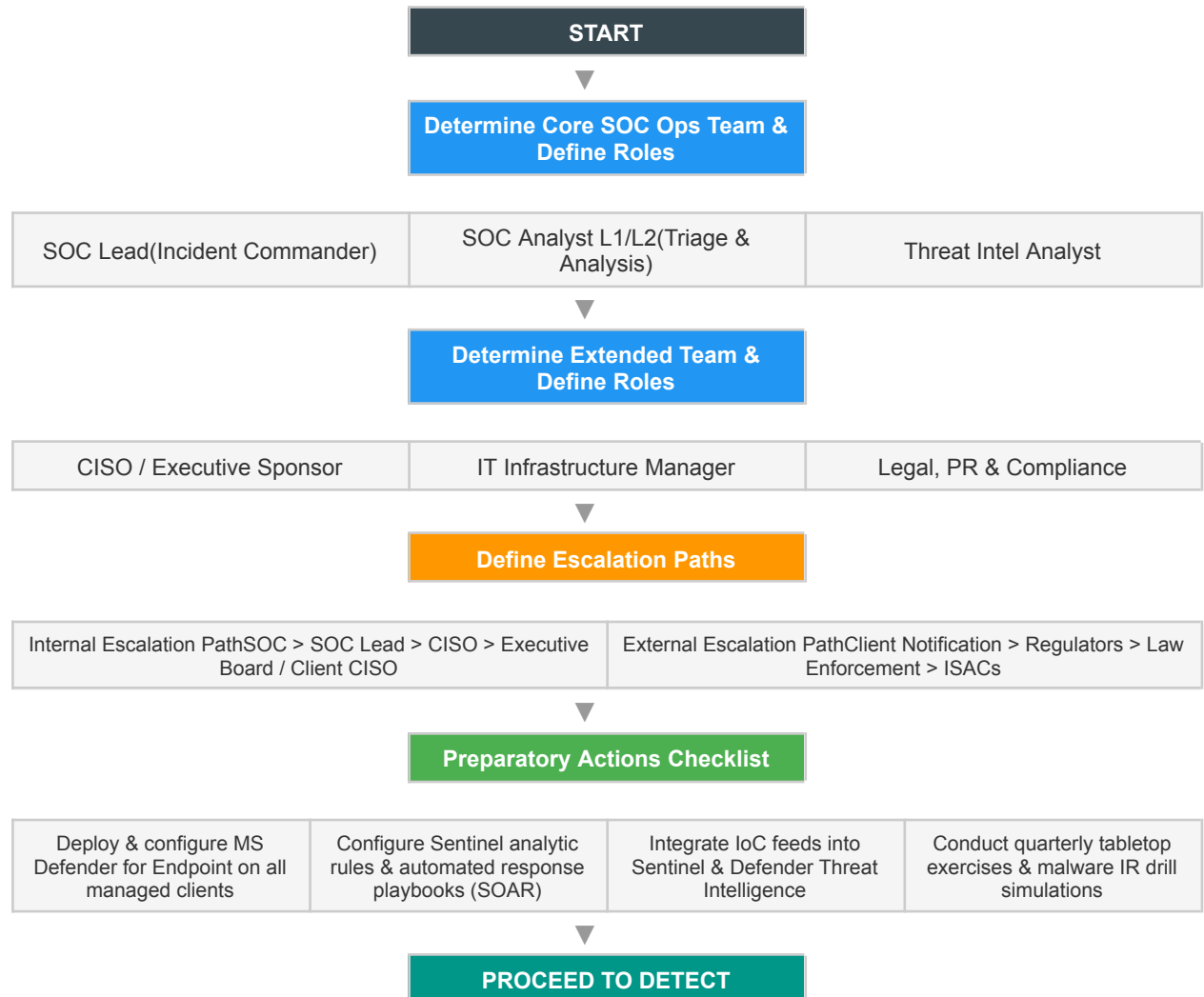
Microsoft Security Tooling Stack

Tool	Purpose	Phase(s)
Microsoft Defender for Endpoint	EDR – endpoint detection, isolation, forensics	Detect, Contain, Eradicate
Microsoft Sentinel (SIEM)	Log aggregation, correlation, automated playbooks	Detect, Analyse, Post-Incident
Microsoft Defender for Office 365	Email & collaboration threat protection	Detect, Contain
Azure Active Directory (Entra ID)	Identity protection, conditional access, MFA	Prepare, Contain, Recover
Microsoft Defender for Cloud	Cloud workload protection, vulnerability mgmt	Prepare, Detect
Microsoft Intune	Endpoint management, compliance, remote wipe	Contain, Eradicate, Recover
Azure Firewall / NSGs	Network segmentation, traffic filtering	Contain, Eradicate
VirusTotal / ANY.RUN	Malware analysis, sandbox detonation	Analyse

PHASE 1: PREPARE

CyberInfiniti Ltd | Page 5

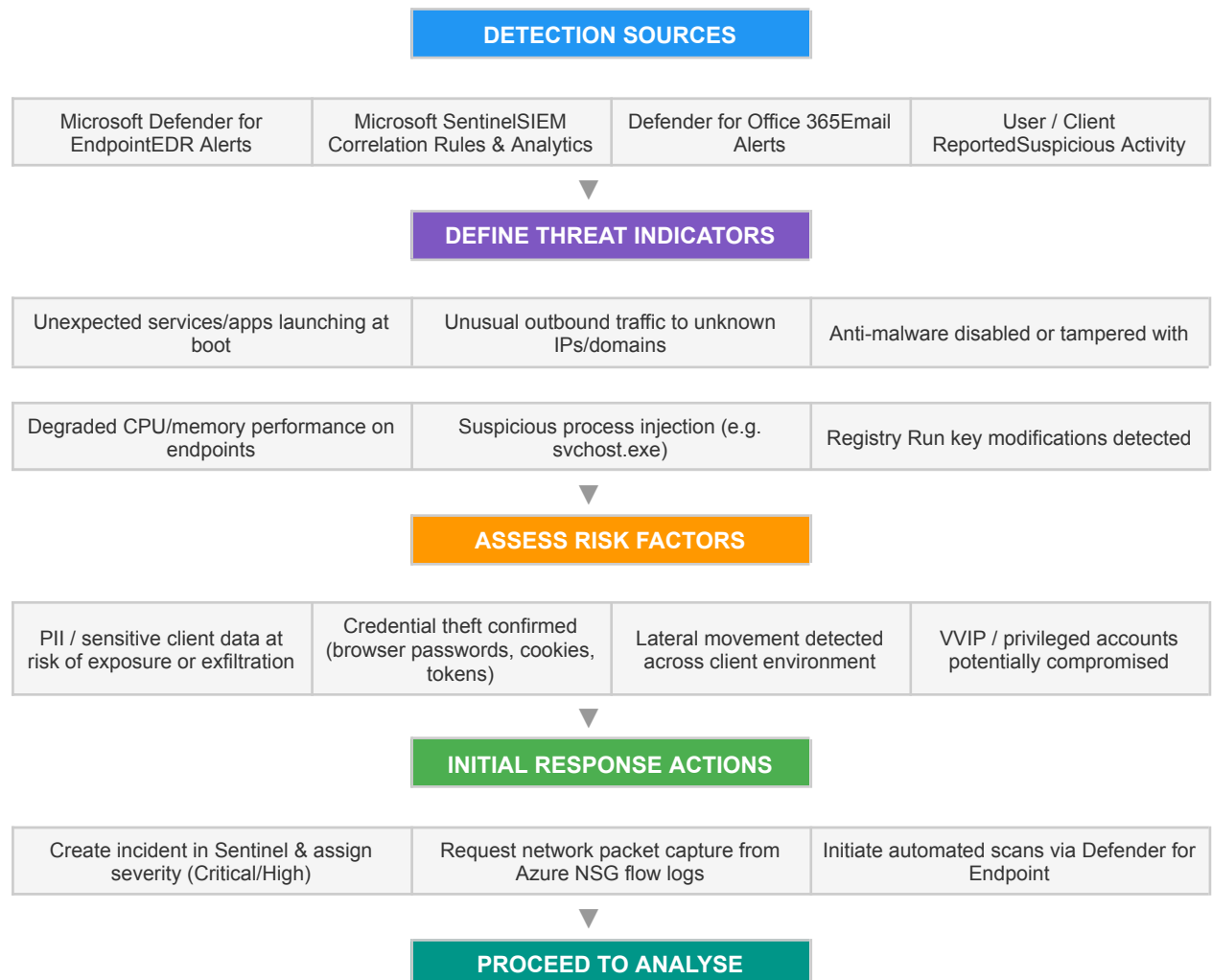
Objective: Establish readiness to detect and respond to malware incidents effectively.



PHASE 2: DETECT

CyberInfiniti Ltd | Page 6

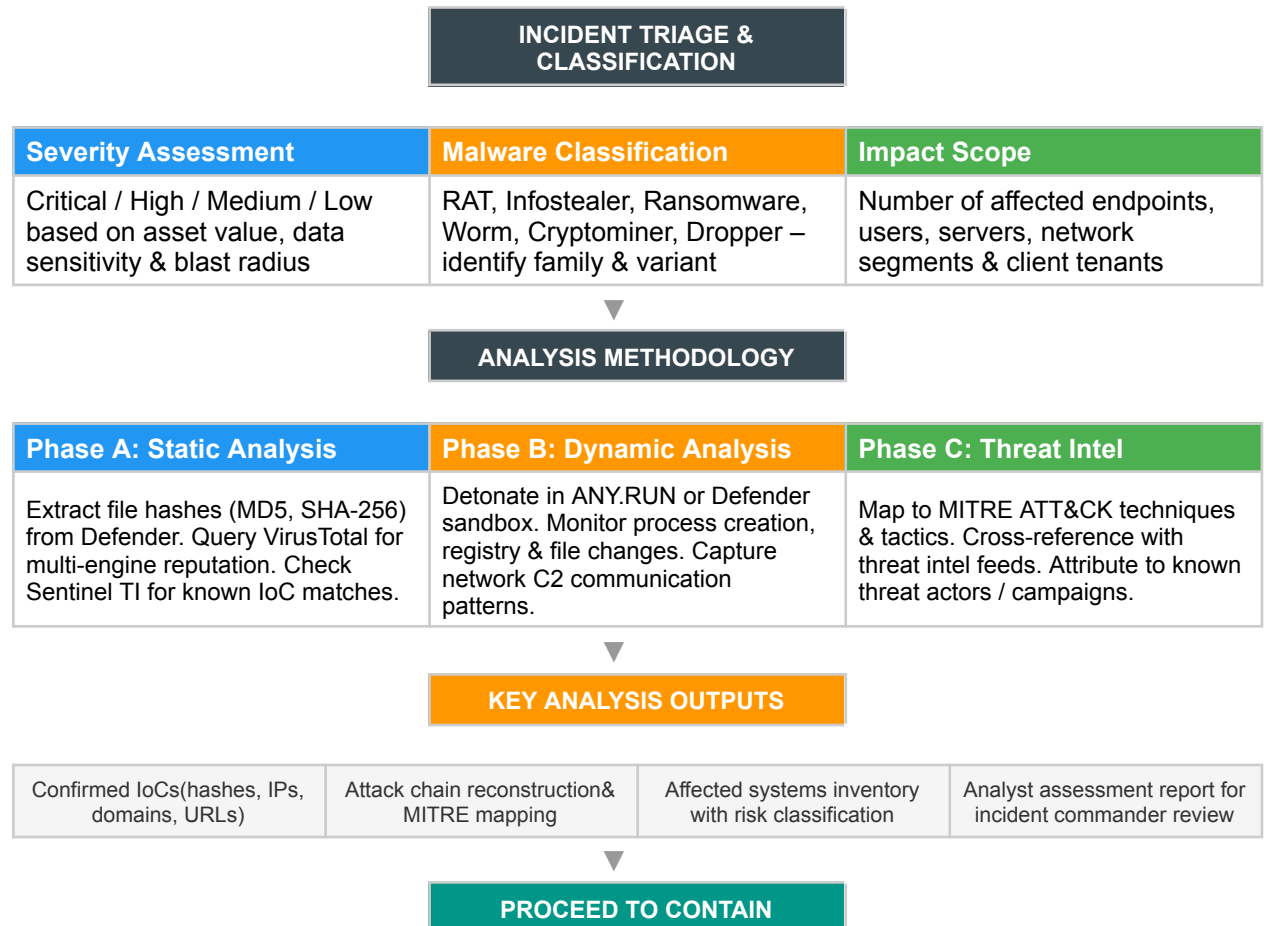
Objective: Identify and validate malware incidents rapidly to minimize spread and impact.



PHASE 3: ANALYSE

CyberInfiniti Ltd | Page 7

Objective: Determine scope, impact, and root cause through structured malware analysis.



PHASE 4: CONTAIN

CyberInfiniti Ltd | Page 8

Objective: Stop the spread of malware and prevent further damage to systems.

CONTAINMENT STRATEGY

SHORT-TERM CONTAINMENT (0-4 Hours)	LONG-TERM CONTAINMENT (4-24 Hours)
Isolate affected endpoints via Defender for Endpoint device isolation	Implement VLAN segmentation for affected network segments via Azure
Block C2 IPs (128.24.231.64/65) at Azure Firewall & NSG rules	Deploy conditional access policies to restrict access from affected devices
Disable compromised user accounts in Azure AD / Entra ID	Enable enhanced audit logging in Sentinel for affected scope
Quarantine malicious files via Defender automated investigation	Block malicious hashes in Defender custom indicator policies
Configure DNS sinkhole for malicious domains in Azure DNS	Notify affected client account managers per MSSP SLA

Re-evaluate scope & escalate ◀ NO	Is containment confirmed effective across all assets?	YES ▶ PROCEED TO ERADICATE
--------------------------------------	---	----------------------------

PHASE 5: ERADICATE

CyberInfiniti Ltd | Page 9

Objective: Remove all traces of malware and close attack vectors.

ERADICATION PROCEDURES

Prevent Further Spread	Remove Malware	Communications
Run samples in Defender sandbox for confirmation	Terminate malicious processes (PIDs identified)	Notify client via encrypted channel
Disable compromised services & scheduled tasks	Delete malware from %TEMP% & AppData dirs	Update incident ticket in Sentinel workspace
Adjust Azure Firewall rules to block IoCs	Revert unauthorised registry modifications	Brief SOC Lead & CISO on progress
Update Sentinel analytic rules	Full AV scan on all endpoints	Document all actions in forensic timeline

IMPORTANT: Memory Forensics

Capture volatile memory from affected systems before remediation to identify in-memory-only malware components. Use Microsoft Defender for Endpoint live response for remote memory acquisition.

▼
PROCEED TO RECOVER

Objective: Restore affected systems to normal operations and strengthen defences.

RECOVERY OPERATIONS

Recover Systems	Recover Data & Credentials	Remediation & Hardening
Re-image affected systems from known-clean backups	Force global password reset (priority: VVIP & admin accts)	Apply all outstanding security patches via Intune
Update IDS/IPS signatures in Azure Firewall	Enforce MFA via Azure AD Conditional Access policies	Wipe & baseline affected systems to corporate SOE
Remove temporary containment measures	Revoke & rotate all API keys and tokens	Push updated AV signatures coordinated with MS Defender
Verify Defender agent health on all endpoints	Restore data from clean backup if exfiltration confirmed	Scan file shares with updated threat definitions

30-DAY ENHANCED MONITORING PERIOD

Implement increased logging verbosity across Sentinel workspace. Configure automated alerting for any IoC re-occurrence. Schedule daily SOC review of affected client environments for a minimum of 30 days.

PROCEED TO POST-INCIDENT

PHASE 7: POST-INCIDENT HANDLING

CyberInfiniti Ltd | Page 11

Objective: Conduct lessons learned, review and implement improvements to prevent recurrence.

Step	Description
INCIDENT REVIEW	Schedule post-incident review within 14 days of closure. All SOC team members, CISO, IT Infra & client stakeholders to attend.
DATA EXPOSURE ASSESSMENT	Was PII or sensitive client data compromised? Was credential theft confirmed? Assess regulatory notification requirements.
LESSONS LEARNED DISCOVERY	Identify detection gaps, response delays, tooling limitations. Document what worked well and what needs improvement.
POLICY & PROCESS UPDATES	Update incident response playbooks, Sentinel detection rules, Defender policies, and client SLA procedures based on findings.
CONFIGURATION UPDATES	Apply technical improvements: new Sentinel analytic rules, updated Defender custom indicators, enhanced conditional access policies.
RESPONSE WORKFLOW UPDATED	Update this playbook with any new procedures, IoCs, or decision points identified during the incident. Version control all changes.

END

Strategic Recommendations

- Deploy application whitelisting to prevent execution of unsigned binaries from %TEMP% and %APPDATA%
- Implement micro-segmentation for critical server infrastructure to limit lateral movement
- Conduct quarterly purple team exercises simulating archive-based delivery & LotL techniques
- Accelerate Zero Trust adoption: least-privilege access, continuous authentication, micro-perimeters
- Subscribe to commercial threat intel feeds and integrate directly into Sentinel & Defender
- Targeted security awareness training for VVIP/privileged users with quarterly phishing simulations

INDICATORS OF COMPROMISE (IoCs) REFERENCE

CyberInfiniti Ltd | Page 12

Deploy immediately across Sentinel, Defender for Endpoint, Azure Firewall, and DNS filtering solutions.

File Hashes

Type	Value	Description
MD5	e8186d5f86cba061f0b6913a952cc60e	AsyncRAT (mini_installer)
MD5	f30ac924dc003a7f7ddb676a1c9c0779	Raccoon Stealer (MuiUnattend.exe)
SHA-256	317e0a76962ba5435726b570ff84ac25...	AsyncRAT payload
SHA-256	b773ca84f8a93ac8477e377178499e5f...	Raccoon Stealer payload

Network Indicators

Type	Value	Description
IP Address	128.24.231.64	Primary C2 / Exfiltration server
IP Address	128.24.231.65	Secondary C2 / Microsoft spoofing
Domain	login.live.com	Abused for HTTP POST credential exfiltration
Domain	settings-win.data.microsoft.com	Data tunnelling and C2 communication (TLS 1.2)
Domain	bing.com	Network connectivity check before C2 callback

Host-Based Indicators

Category	Indicator
Registry Keys	HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run
Registry Keys	HKCU\SOFTWARE\WinRAR\ArcHistory
File Paths	C:\Users*\AppData\Local\Temp*.exe
File Paths	C:\Users*\AppData\Local\Temp*.zip
Processes	svchost.exe (injected) – verify parent process legitimacy
Processes	MoUsoCoreWorker.exe (masquerading)

MITRE ATT&CK Techniques Observed

Technique ID	Name	Tactic
T1204	User Execution	Execution
T1055	Process Injection	Defense Evasion, Privilege Escalation
T1547.001	Registry Run Keys / Startup Folder	Persistence
T1071	Application Layer Protocol	Command & Control
T1005	Data from Local System	Collection
T1036	Masquerading	Defense Evasion
T1074	Data Staged	Collection
T1053	Scheduled Task/Job	Persistence, Execution

Escalation Matrix

Severity	Notification	Stakeholders	Channel
CRITICAL	Within 1 hour	CISO, Client CISO, Board, Legal, Regulators	Encrypted call + Secure email
HIGH	Within 4 hours	SOC Lead, CISO, Client Account Manager	Secure email + Ticket system
MEDIUM	Within 24 hours	SOC Lead, IT Infrastructure	Ticket system + Email
LOW	Next business day	SOC Analyst, IT Infrastructure	Ticket system

Internal Communication Protocol

- All incident communications via encrypted email (S/MIME or PGP) and secure conferencing
- No incident details on personal devices, unencrypted channels, or public messaging platforms
- Situation updates every 12 hours during active incident to all designated stakeholders
- Full incident report delivered within 72 hours of containment confirmation

External Communication Protocol (MSSP Client Notifications)

- Notify affected clients per MSSP SLA terms (typically within 4 hours of confirmed breach)
- Provide client with sanitised IoC list for their own internal blocking and threat hunting
- Coordinate with client legal team on regulatory notification requirements (GDPR, POPIA, etc.)
- Share threat intelligence with relevant ISACs and industry sharing partners (anonymised)
- Provide final incident report to client within agreed SLA timeframe

RACI Matrix

Activity	SOC Analyst	SOC Lead	CISO	IT Infra	Client
Initial Detection & Triage	R	A	I	I	I
Malware Analysis	R	A	I	C	-
Containment Execution	R	A	I	R	I
Eradication & Cleanup	R	A	I	R	I
Credential Reset & Recovery	C	A	I	R	R
Client Notification	C	R	A	I	I
Post-Incident Review	R	R	A	C	C
Playbook Update	R	A	I	C	-

R = Responsible | A = Accountable | C = Consulted | I = Informed

Affected Systems (from Malware Analysis Report)

System Name	Type	Status	Priority
ERP-PROD-002	Production Server	Compromised – Remediation In Progress	CRITICAL
DATA-PROD-001	Production Server	Compromised – Remediation In Progress	CRITICAL
DATA-PROD-002	Production Server	Compromised – Remediation In Progress	CRITICAL
Laptop-01324	VVIP Workstation	Compromised – Isolated	CRITICAL
Laptop-22123	VVIP Workstation	Compromised – Isolated	HIGH
Laptop-31214	VVIP Workstation	Compromised – Isolated	HIGH

Attack Chain Reconstruction

1User visits malicious domain	2ZIP archive downloaded	3WinRAR extracts to %TEMP%	4AsyncRAT & Raccoon Stealer execute	5Process injection into svchost.exe	6C2 comms & credential exfiltration
-------------------------------	-------------------------	----------------------------	-------------------------------------	-------------------------------------	-------------------------------------

Persistence Mechanisms Identified

MITRE ID	Technique	Evidence	Remediation
T1547.001	Registry Run Keys	HKCU\...\Run modified	Revert registry entries
T1074	Temp Directory Abuse	Binaries in AppData\Temp	Delete & scan %TEMP%
T1036	Service Masquerading	svchost.exe injected	Terminate & re-image
T1053	Scheduled Tasks	Suspected task creation	Audit & remove tasks

CyberInfiniti Ltd – Security Operations Centre

This playbook was created by the CyberInfiniti SOC Team for standardised incident response.
Classification: CONFIDENTIAL | Review: Quarterly | Next Review: October 2025

CYBERINFINITI

SECURITY OPERATIONS

EMAIL INVESTIGATION & ANALYSIS PLAYBOOK

Phishing • Credential Harvesting • Malware Delivery

Microsoft 365 / Exchange Online Environment

Document Type	Incident Response Playbook
Classification	Internal — Security Operations
Version	1.0
Prepared by	CyberInfiniti SOC Team

Table of Contents

1.	Executive Summary	3
2.	Scope & Objectives	3
3.	Roles & Responsibilities	4
4.	Incident Response Lifecycle	5
5.	Phase 1 — Prepare	6
6.	Phase 2 — Identify (Detection & Reporting)	7
7.	Phase 3 — Triage & Analysis	8
8.	Phase 4 — Containment	10
9.	Phase 5 — Eradication	11
10.	Phase 6 — Recovery	12
11.	Phase 7 — Lessons Learned	13
12.	Investigation Case Studies (5 Emails)	14
13.	Indicators of Compromise (IOCs)	20
14.	Microsoft 365 Response Reference	21
15.	Appendix — Tools & References	22

1. Executive Summary

This playbook documents the Email Investigation and Analysis programme operated by the CyberInfiniti Security Operations Centre (SOC) for users of the Microsoft 365 / Exchange Online environment. It defines the end-to-end response lifecycle for suspicious or malicious emails, from user reports through triage, containment, eradication, recovery and lessons learned.

During the most recent operations sprint, five (5) reported email threats were investigated. Analysis revealed a mix of benign, suspicious and clearly malicious messages employing impersonation of trusted brands (Adobe, internal teams), abuse of legitimate cloud infrastructure (Gmail relays, Google Drive), credential-harvesting URLs, and direct delivery of executable payloads.

Sprint Snapshot — 5 Emails Analysed

- 1 Benign / Unsolicited: Affiliate Marketing Best Practices
- 1 Suspicious: Team Building Activity (theannoyingsite.com)
- 3 Malicious: Code Review Request, Download Updated Project Files, Important Adobe Update
- Primary techniques: brand impersonation, display-name spoof, malicious URL, .exe payload delivery

2. Scope & Objectives

This playbook applies to all email reported to the SOC via the Microsoft Outlook Report Phishing add-in, the abuse mailbox, automated alerts from Microsoft Defender for Office 365, and escalations from the IT Service Desk.

Objectives

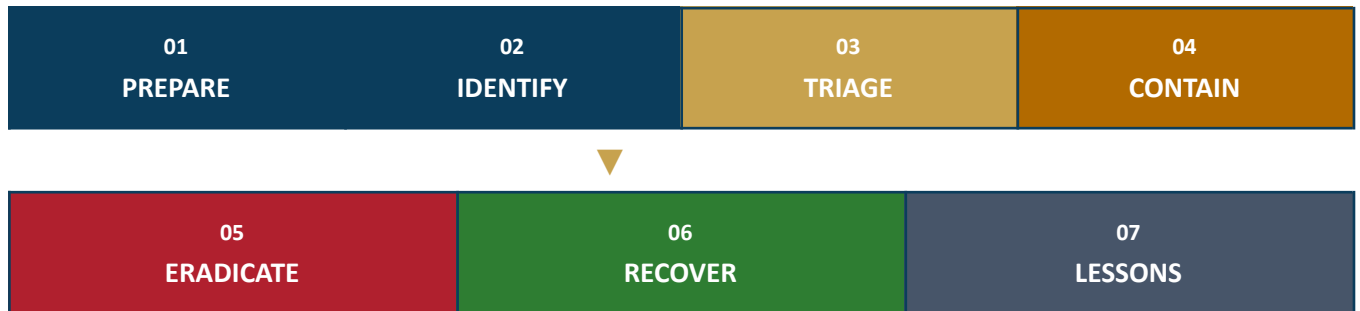
- Provide a repeatable, evidence-driven workflow for triaging reported email.
- Reduce mean time to contain (MTTC) malicious email below 60 minutes.
- Eliminate the threat from all affected mailboxes and prevent re-delivery.
- Capture indicators of compromise (IOCs) and feed them to detection controls.
- Drive measurable improvement in user reporting quality and resilience.

3. Roles & Responsibilities

Role	Responsibility
End User	Reports suspicious email via the Outlook Report Phishing button or abuse@company.com without forwarding, replying or clicking embedded content.
Service Desk (Tier 1)	Acknowledges report, confirms scope (single user vs. campaign), opens ticket, hands off to SOC.
SOC Analyst (Tier 2)	Owns the investigation: header analysis, URL/attachment detonation, IOC enrichment, verdict determination.
SOC Lead / Incident Manager	Authorises containment actions (mailbox purge, sender/domain block, account lockdown). Owns communication.
Threat Intel	Enriches IOCs against external feeds, correlates with prior campaigns, publishes a threat advisory.
IT Operations	Applies blocks at the email gateway, web proxy and DNS. Resets credentials and rebuilds compromised endpoints when required.
Communications / HR	Coordinates user-facing communication and any disciplinary or training follow-up.

4. Incident Response Lifecycle

The CyberInfiniti email-investigation lifecycle aligns with NIST SP 800-61r2 and is tuned for a Microsoft 365 environment. Each phase has explicit entry criteria, owner, key actions and exit criteria.



Guiding Principle

Every reported email is treated as suspicious until proven otherwise. Verdicts are evidence-driven (headers, reputation, sandbox behaviour) — never based on subject line, display name or user opinion alone.

Preparation ensures the SOC, technology stack and end users are positioned to detect and respond to email-borne threats before an incident occurs.

Technology Readiness

- Microsoft Defender for Office 365 (MDO) — Safe Links, Safe Attachments, anti-phish and anti-spam policies tuned and enforced.
- Exchange Online Protection (EOP) — connection filtering, transport rules, DKIM signing for owned domains, DMARC at p=quarantine or p=reject.
- Microsoft Sentinel — ingestion of Office 365, AAD Sign-In, and Defender alerts for correlation.
- Tenant Allow/Block Lists (TABL) configured for senders, domains, URLs and file hashes.
- Outlook Report Phishing add-in deployed to all mailboxes; submissions routed to Microsoft and the SOC.

Process Readiness

- Documented playbook, runbooks and decision trees stored in the SOC knowledge base.
- Defined service levels: acknowledge ≤ 15 min, triage ≤ 60 min, contain ≤ 4 h for confirmed malicious.
- Quarterly tabletop exercises against realistic phishing scenarios.

People Readiness

- Mandatory phishing-awareness training on hire and annually.
- Quarterly simulated phishing campaigns with targeted remediation training.
- Clear, blame-free reporting culture — users are recognised for reporting, including false positives.

PHASE 2**IDENTIFY (DETECTION & REPORTING)**

Detection sources for reported and auto-discovered email threats.

Source	Description
User Report (Outlook add-in)	Primary channel. Submission lands in the SOC review queue and is co-submitted to Microsoft.
Abuse Mailbox	abuse@company.com — fallback when the add-in is unavailable. Auto-parsed by SOAR.
MDO Alerts	Zero-hour Auto Purge (ZAP), high-confidence phishing, malware detonation, impersonation alerts.
Sentinel Analytics	Cross-source correlation: suspicious sign-in following email click, mass-delete rules, anomalous forwarding.
Threat Intel Feed	External IOCs matched against historical mail flow via threat-hunting queries.

What the Analyst Captures at Intake

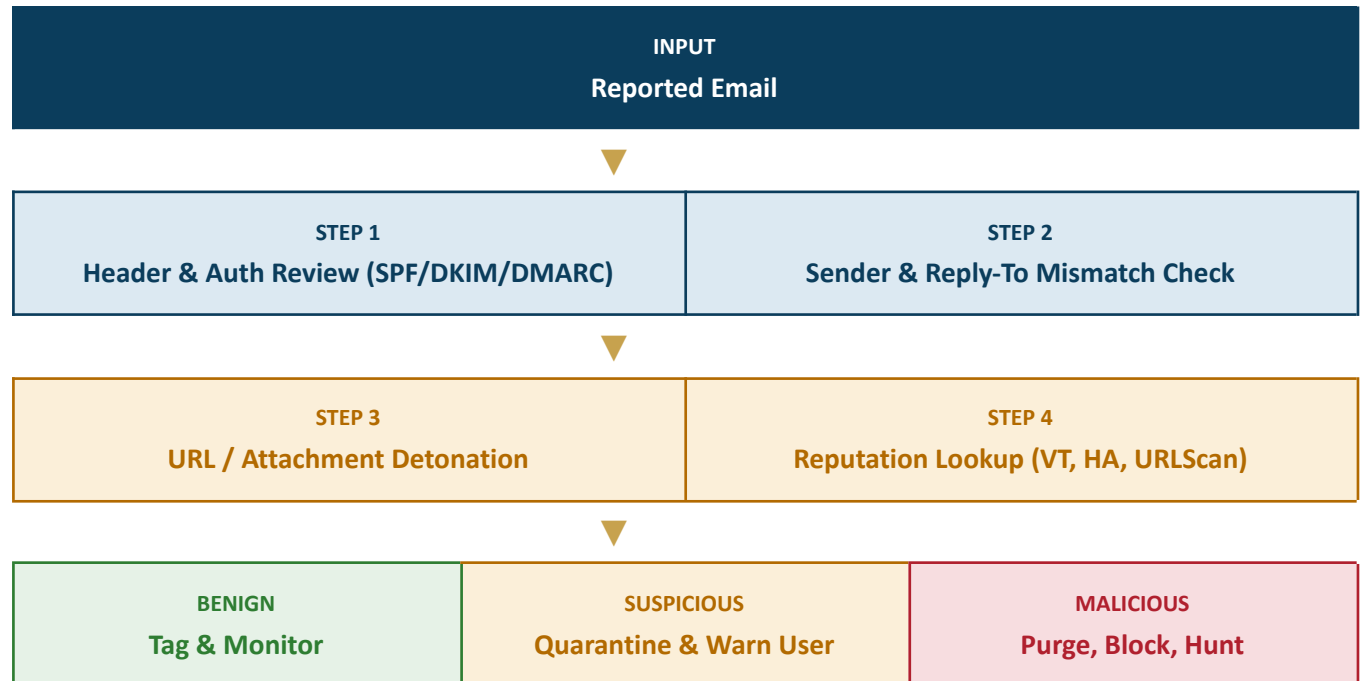
Reporter, recipient(s), subject, sending address, sending IP, reply-to, full headers, original .eml, all URLs, attachment hashes, time of receipt and time of report.

PHASE 3

TRIAGE & ANALYSIS

Triage determines verdict (Benign / Suspicious / Malicious) using a deterministic, evidence-driven workflow.

Triage Decision Flow



Triage Severity Matrix

Severity	Indicators	Examples (this report)	Initial Action
Low (Benign)	Auth pass, clean reputation, unsolicited only	Affiliate Marketing email	Tag, monitor, user awareness
Medium (Suspicious)	Display-name spoof, abusive link, weak context	Team Building Activity (theannoyingsite.com)	Quarantine, warn user, block URL
High (Malicious)	Credential harvester, payload (.exe), VT detections	Code Review Request, Adobe Update, Project Files	Purge from mailboxes, block sender + domain, EDR sweep

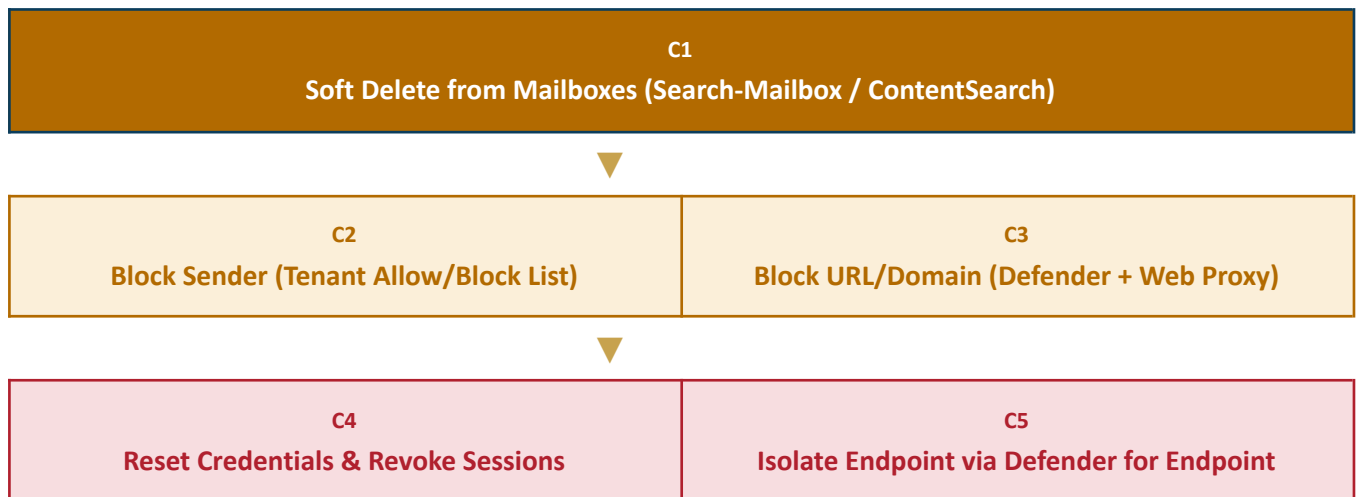
Header Authentication — What to Check

- SPF — does the sending IP match the From-domain's SPF record?
- DKIM — is the signature valid and aligned with the From-domain?
- DMARC — does the message align (SPF or DKIM) with the From-domain and meet the policy?

- Reply-To vs From — mismatched reply-to is a classic phishing tell.
- Display Name vs Address — friendly name impersonating a brand while sending from a free webmail relay (e.g. Gmail) is a high-confidence indicator.

PHASE 4**CONTAINMENT**

Containment removes the threat from the environment and prevents further exposure while the full investigation continues.

**Microsoft 365 Containment Actions**

- Soft-delete the message from all recipient mailboxes via Microsoft Purview Content Search → Purge (SoftDelete).
- Add sender address and root domain to the Tenant Allow/Block List (TABL).
- Submit URL and root domain to Defender Safe Links and the corporate web proxy block list.
- Submit attachment hash to Defender for Endpoint custom indicators (Block & Remediate).
- If a user clicked / entered credentials: revoke all active sessions in Entra ID, force password reset, enforce re-MFA, audit mailbox forwarding rules and OAuth grants.
- If a payload executed: isolate device via Defender for Endpoint, collect investigation package, escalate to malware-outbreak playbook.

Eradication removes all traces of the threat and underlying weaknesses that allowed delivery.

- Confirm message removal across every recipient mailbox (including Recoverable Items / Purges folder where licensing permits).
- Hunt across mail flow for the same sender, subject, URL, attachment hash and SHA256 over the prior 30 days using Threat Explorer and Advanced Hunting (KQL).
- Hunt across endpoints for execution of the payload, child processes and outbound network connections to the C2.
- Hunt across identity for sign-ins originating from suspicious IPs/ASNs following the click time.
- Strengthen detections: convert observed IOCs into Sentinel analytic rules and TABL entries; tune anti-phish impersonation policy if a brand spoof was used.

Sample KQL Hunt — URL Click Telemetry

UrlClickEvents

| where Timestamp > ago(30d)

| where Url has_any ("wtools.io", "theannoyingsite.com", "contaboserver.net")

| project Timestamp, AccountUpn, Url, ActionType, IPAddress, ThreatTypes

Recovery restores affected users and systems to a known-good, monitored state.

- Restore mailbox access and confirm no malicious inbox rules, forwarders or delegates remain.
- Re-enable user accounts after credential reset, MFA re-enrolment and conditional-access review.
- Return rebuilt or remediated endpoints to production after EDR clean-bill-of-health.
- Communicate resolution to the reporting user and (where appropriate) line manager.
- Apply a 14-day heightened-monitoring window for affected accounts and devices.

Continuous improvement closes the loop. A lessons-learned review is conducted within 5 business days of every confirmed malicious incident.

- Root cause: how was the message delivered, why was it not caught, and what allowed any subsequent compromise?
- Detection gap: what new analytic rule, TABL entry, transport rule or policy will catch the next variant?
- User behaviour: were the right users targeted? Do they need additional training or a focused simulation?
- Process: did the SLA hold? Where was time lost? Update the runbook and decision tree accordingly.
- Metrics: feed MTTD, MTTR, click-rate and report-rate into the monthly SOC scorecard.

12. Investigation Case Studies

The five case studies below are drawn from the most recent operations sprint and demonstrate the playbook applied end-to-end. Each case follows the same structure: artefacts collected, content overview, behavioural analysis, indicators observed and verdict.

Case 1: Affiliate Marketing Best Practices

Email Description and Artifacts Collected

Sending Address	jasonconrad099@gmail.com
Subject Line	Affiliate Marketing Best Practices
Recipient	kendrick.lawal@company.com
Sender IP	209.85.216.49
Reverse DNS	mail-pj1-f49.google.com
Reply-To	jasonconrad099@gmail.com
Date / Time	Sat, 29 Jul 2023 15:46:13 +0100
Full URL	https://www.authorityhacker.com/successful-affiliate-websites-examples/?referral_code=aef49w31123
Root Domain / IP	authorityhacker.com / 104.26.15.11

Content Overview

Sent from a Gmail account, the email shares an article about affiliate marketing and invites the recipient to visit an external website via a link containing a referral code. It is presented as a helpful resource from a peer.

Behavioural Analysis

The message uses a legitimate-looking business topic and a friendly tone to encourage link clicking. The presence of a referral parameter suggests affiliate-tracking intent rather than direct exploitation.

Key Indicators Observed

- SPF, DKIM and DMARC all PASS — message is properly authenticated.
- VirusTotal: 0/95 detections on URL and root domain.
- URL2PNG and ANY.RUN render the destination as a genuine homepage with no fake login or payload.
- Hybrid Analysis returns no specific threat.

- Reverse DNS on 209.85.216.49 confirms origin from mail-pj1-f49.google.com (legitimate Google relay).

VERDICT: NON-MALICIOUS — Likely benign / unsolicited — treat with caution; not a trusted internal communication.

Case 2: Code Review Request

Email Description and Artifacts Collected

Sending Address	zelatcol@gmail.com
Subject Line	Code Review Request
Recipient	michelle.jackson@company.com
Sending Server IP	209.85.214.178
Reverse DNS	mail-pl1-f178.google.com
Reply-To	zelatcol@gmail.com
Date / Time	Sat, 29 Jul 2023 15:22:06 +0100
Full URL	https://wtools.io/paste-code/bOs4
Root Domain / IP	wtools.io / 188.166.15.204

Content Overview

A targeted social-engineering attempt that uses a fake code-review request to lure a developer into pasting source code into an attacker-controlled site, exposing both code and any embedded secrets.

Behavioural Analysis

Although headers authenticate cleanly via Gmail relay, the embedded URL has a confirmed malicious reputation and is associated with NJRat malware activity. The lure is industry-specific and credible to a software engineer.

Key Indicators Observed

- VirusTotal: 13/95 vendors flag the URL as malicious; links to NJRat infrastructure.
- WHOIS: domain registered ~2 years ago via Namecheap with no public registrant detail.
- ANY.RUN: destination returns 404 — likely taken offline after malicious use.
- URL2PNG: snapshot confirms a fake code-review portal designed to harvest pasted source.
- Hybrid Analysis and urlscan.io both flag the site as malicious.

VERDICT: MALICIOUS — Malicious — credential / code harvester. Block sender, purge from mailboxes, hunt for clicks.

Case 3: Download Updated Project Files

Email Description and Artifacts Collected

Sending Address	projectdept@kanzalshamsprojectmgt.com
Subject Line	Download Updated Project Files
Recipient	nikefury@company.com
Sending Server IP	209.85.216.41
Reverse DNS	mail-pj1-f41.google.com
Reply-To	projectdept@kanzalshamsprojectmgt.com
Date / Time	Sat, 29 Jul 2023 15:37:34 +0100
Full URL	https://drive.google.com/uc?export=download&id=1bstuGMLer-fbJbcGG5JiqnleKTSKvq5y

Content Overview

Posing as a Project Management Office, the email claims that requested project files are ready and provides a direct download link hosted on Google Drive — abusing trusted cloud infrastructure to bypass URL reputation controls.

Behavioural Analysis

Task-oriented language creates urgency and legitimacy. The use of a generic Gmail relay combined with a Google Drive download link is a recognised pattern for malware delivery and credential harvesting.

Key Indicators Observed

- SPF / DKIM / DMARC PASS but display-name vs. sender domain mismatch.
- Sending domain (kanzalshamsprojectmgt.com) inconsistent with relay (Gmail) — classic spoofing posture.
- Drive object flagged on VirusTotal; root domain known abused for malware staging.
- Hostname check via WhatIsMyIPAddress confirms generic Google relay path.
- No prior business relationship with the sending entity — unsolicited.

VERDICT: MALICIOUS — High-risk — likely phishing / malware delivery via Google Drive. Do not interact outside sandbox.

Case 4: Important Adobe Update

Email Description and Artifacts Collected

Sending Address	alfredegov@gmail.com
Subject Line	Important Adobe Update
Recipient	lily.tunechy@company.com
Sending Server IP	209.85.215.170
Reverse DNS	mail-pj1-f41.google.com
Reply-To	alfredegov@gmail.com
Date / Time	Sat, 29 Jul 2023 15:54:42 +0100
Full URL	http://vmi1159541.contaboserver.net/payload.exe
Root Domain / IP	vmi1159541.contaboserver.net / 209.145.51.44

Content Overview

Brand-impersonation attack from a Gmail account posing as the Adobe Support Team. Claims an urgent software update is required and links to a downloadable .exe payload hosted on a non-trusted server.

Behavioural Analysis

Uses urgency and authority (security update) to pressure the user into executing the payload. The displayed link suggests an Adobe update while the actual href points to an unrelated hosting domain — classic deceptive-link technique.

Key Indicators Observed

- SPF / DKIM / DMARC PASS but sender impersonates Adobe from a Gmail address.
- Spam Confidence Level (SCL): 5 — elevated.
- Direct link to an .exe file on vmi1159541.contaboserver.net — VirusTotal: malicious.
- WHOIS: domain registered 2017-03-05 via RegistryGate GmbH.
- URL2PNG: destination served credential-harvesting content prior to takedown.

VERDICT: MALICIOUS — Malicious — brand impersonation + executable payload. Treat as highly dangerous.

Case 5: Team Building Activity

Email Description and Artifacts Collected

Sending Address	alfredegov@gmail.com
Subject Line	Team Building Activity
Recipient	shina.kagawa@company.com
Sending Server IP	209.85.210.182
Reverse DNS	mail-pf1-f182.google.com
Reply-To	alfredegov@gmail.com
Date / Time	Sat, 29 Jul 2023 16:27:56 +0100
Full URL	http://theannoyingsite.com/
Root Domain / IP	theannoyingsite.com / 209.145.51.44

Content Overview

A casual-toned message posing as a colleague invites the recipient to visit theannoyingsite.com under the guise of a fun team-building activity. There is no business context and no personalisation.

Behavioural Analysis

Low-sophistication social-engineering lure designed to nudge users toward a non-business external site that aggressively abuses browser features (clipboard access, drive-by downloads, fake logout endpoints, popup spam).

Key Indicators Observed

- External Gmail sender; same address used in the Adobe Update case (campaign linkage).
- VirusTotal: 13/95 vendors flag the destination.
- ANY.RUN: clipboard access, attempted drive-by download (cat-marshmallows.jpg), fake logout endpoints, popup spam.
- WHOIS: domain registered ~9 years ago via Namecheap.
- URL2PNG: hosts a fake login portal at landing.

VERDICT: SUSPICIOUS — Suspicious / phishing-adjacent — quarantine, warn user, block at proxy.

13. Indicators of Compromise (IOCs)

Consolidated IOCs from this sprint. Push to TABL, web proxy, EDR custom indicators and Sentinel watchlists.

Type	Indicator	Notes
Sender Address	zelatcol@gmail.com	Code Review Request — malicious
Sender Address	projectdept@kanzalshamsprojectmgt.com	Project Files lure — malicious
Sender Address	alfredegov@gmail.com	Adobe Update + Team Building — malicious / suspicious
URL	https://wtools.io/paste-code/bOs4	Code/credential harvester (NJRat)
URL	http://vmi1159541.contaboserver.net/payload.exe	.exe payload — Adobe impersonation
URL	http://theannoyingsite.com/	Abusive site — drive-by behaviour
URL	https://drive.google.com/uc?export=download&id=1bstuGMLer-fbJbcGG5JiqnleKTSKvq5y	Drive-hosted payload
Domain	wtools.io	Block at web proxy and Safe Links
Domain	vmi1159541.contaboserver.net	Block at web proxy and Safe Links
Domain	theannoyingsite.com	Block at web proxy and Safe Links
IP	188.166.15.204	wtools.io
IP	209.145.51.44	Contaboserver / theannoyingsite shared host

14. Microsoft 365 Response Reference

Operational reference for the most common containment and eradication actions in a Microsoft 365 / Exchange Online tenant.

Tenant Allow/Block List (TABL)

- Microsoft 365 Defender → Policies & Rules → Threat policies → Tenant Allow/Block Lists.
- Add entries for Senders, Domains, URLs and File Hashes with an expiry and a justification note.

Purging Mail from Mailboxes

- Microsoft Purview → Content Search → build a query (sender, subject, date) → Preview → Purge → SoftDelete.
- For high-volume incidents, use New-ComplianceSearchAction -Purge -PurgeType SoftDelete via Security & Compliance PowerShell.

Defender for Office 365 — Threat Explorer

- Use Threat Explorer to confirm delivery scope, view URL clicks, and submit messages to Microsoft for analysis.
- Trigger AIR (Automated Investigation & Response) to validate hunts and queue remediation.

Identity Containment (Entra ID)

- Revoke all refresh tokens (Revoke-AzureADUserAllRefreshToken / Revoke-MgUserSignInSession).
- Force password reset, require re-MFA, review and remove rogue OAuth consents.
- Audit mailbox rules (Get-InboxRule) and remove suspicious forwarders.

Endpoint Containment (Defender for Endpoint)

- Isolate device, collect investigation package, run live response, push custom indicator (hash/URL/IP).

15. Appendix — Tools & References

Investigation & Enrichment Tools

- VirusTotal — URL, domain, IP, file hash reputation.
- Hybrid Analysis — automated sandbox detonation.
- ANY.RUN — interactive sandbox for URL and file analysis.
- URL2PNG — safe rendering of suspicious URLs.
- urlscan.io — URL scanning and historical data.
- MxToolbox — DNS, reverse DNS, blacklist and SPF/DMARC checks.
- DigTrace / WannaBrowser — DNS query inspection and HTTP request emulation.
- Microsoft 365 Defender, Threat Explorer, Advanced Hunting (KQL).
- Microsoft Sentinel — SIEM correlation and analytics.

References

- NIST SP 800-61r2 — Computer Security Incident Handling Guide.
- MITRE ATT&CK — Initial Access (T1566 Phishing) and sub-techniques.
- Microsoft Defender for Office 365 documentation.
- CISA — Phishing Guidance for End Users and Organisations.

Document Control

Owner: CyberInfiniti SOC. Review cadence: every 6 months or after any major incident.

Distribution: SOC, IT Operations, Service Desk, Compliance. Classification: Internal.